

Security+ 2.3 · OS Vulnerabilities

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — OS Vulnerabilities (4:09) · [vídeo original ↗](#) · [YouTube ↗](#)

Falha no sistema operacional (kernel, serviços, bibliotecas). Windows tem Patch Tuesday — dezenas de correções por mês. SO sem patch = alvo fácil. Zero-day OS = sem correção disponível. Defesa: patch ASAP, EDR.

Highlights que a prova cobra

- Patch Tuesday: Microsoft corrige dezenas de CVE por mês
- Legacy (XP): sem suporte, sem patch — desativar/segmentar

Dicas de prova

- 'operating system lacks patches' = legacy/unsupported OS vulnerability

Cenário clássico: Cenário: 'Windows XP na rede industrial porque o software critico não roda no moderno' = legacy OS risk.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:
- A)** CVE pública
 - B)** Zero-day
 - C)** Backdoor
 - D)** Falso positivo

2. Qual tipo de ataque explora vulnerabilidades antes que um patch esteja disponível?

- A)** Ataque de dia zero (Zero-day)
- B)** Ataque DDoS
- C)** Ataque de força bruta
- D)** Ataque Man-in-the-Middle

3. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Patch Tuesday: Microsoft corrige dezenas de CVE por mês'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas de CVE por mês...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Legacy (XP): sem suporte, sem patch — desativar/segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desativar/segmentar...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'operating system lacks patches' = legacy/unsupported OS vulnerability'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'operating system lacks patches' = legacy/unsupported OS vulnerability...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'Windows XP na rede industrial porque o software crítico não roda no moderno' = legacy OS risk.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial porque o software crítico não roda ...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Patch Tuesday: Microsoft corrige dezenas de CVE por mês'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas de CVE por mês...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Legacy (XP): sem suporte, sem patch — desativar/segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desativar/segmentar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'operating system lacks patches' = legacy/unsupported OS vulnerability'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'operating system lacks patches' = legacy/unsupported OS vulnerability...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'Windows XP na rede industrial porque o software critico não roda no moderno' = legacy OS risk.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial porque o software critico não roda ...

GABARITO COMENTADO

1) B — Zero-day. Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção.

2) A — Ataque de dia zero (Zero-day). Zero-day é uma vulnerabilidade recém-descoberta que é explorada antes do desenvolvedor ter conhecimento ou lançar correção (dia zero de conhecimento).

3) B — Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas d. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Patch Tuesday: Microsoft corrige dezenas de CVE por mês. As demais alternativas configuram violações graves de con

4) C — Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desa. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Legacy (XP): sem suporte, sem patch — desativar/segmentar. As demais alternativas configuram violações graves de c

5) A — Implementar a solução correspondente: 'operating system lacks patches' = legacy/. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): 'operating system lacks patches' = legacy/unsupported OS vulnerability. As demais alternativas configuram violação

6) A — Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial po. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Cenário: 'Windows XP na rede industrial porque o software critico não roda no moderno' = legacy OS risk.. As demai

7) A — Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas d. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Patch Tuesday: Microsoft corrige dezenas de CVE por mês. As demais alternativas configuram violações graves de con

8) B — Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desa. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Legacy (XP): sem suporte, sem patch — desativar/segmentar. As demais alternativas configuram violações graves de c

9) A — Implementar a solução correspondente: 'operating system lacks patches' = legacy/. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): 'operating system lacks patches' = legacy/unsupported OS vulnerability. As demais alternativas configuram violação

10) D — Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial po. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Cenário: 'Windows XP na rede industrial porque o software critico não roda no moderno' = legacy OS risk.. As demai

